

Document ID:SEC-2026-001

Version:2.0

Status:Final

Author:James Morton, Security Lead

Print Date:2026-01-16

INTERNAL USE ONLY

Document

1. Overview

This document defines the security requirements, controls, and compliance standards for the DataFlow Platform. All project components, including vendor software, must comply with these policies.

2. Compliance Requirements

The DataFlow Platform must comply with:

- GDPR - EU General Data Protection Regulation
- Swiss DPA - Federal Act on Data Protection (nDSG)
- ISO 27001 - Information Security Management
- SOC 2 Type II - Service Organization Controls

Phase 2 Compliance Gate

Before Phase 2 can launch, the following certifications must be obtained:

Requirement	Owner	Status	Target Date
Penetration Test (External)	InfoSec	Scheduled	Jan 20, 2026
Penetration Test (Internal)	InfoSec	Scheduled	Jan 22, 2026
GDPR Data Mapping	Legal	In Progress	Jan 18, 2026
API Security Review	InfoSec	Not Started	Jan 24, 2026

Critical: Phase 2 launch requires sign-off from James Morton (Security Lead) confirming all security requirements are met.

3. Access Control



3.1 Authentication

- All user access must use SSO (SAML 2.0 or OIDC)
- Service accounts must use certificate-based authentication
- API access requires OAuth 2.0 with JWT tokens
- Token expiration: 1 hour maximum

3.2 Authorization

- Role-Based Access Control (RBAC) required
- Principle of least privilege enforced
- Quarterly access reviews mandatory

3.3 Privileged Access

Role	Access Level	Approval Required
Developer	Read staging data	Team Lead
DevOps	Production infrastructure	Security Lead
DBA	Production database	Security Lead + CTO
Admin	Full system access	CTO + CISO

4. Data Protection

4.1 Encryption Standards

Data State	Requirement	Algorithm
In Transit	Mandatory	TLS 1.3
At Rest	Mandatory	AES-256-GCM
In Backup	Mandatory	AES-256-GCM

Database Encryption: All tables containing PII must use column-level encryption in addition to disk encryption.

4.2 Data Audit Trail

For compliance with GDPR Article 30, the following audit requirements apply:

Required Audit Events:

- All data access (read/write)
- Authentication events (success/failure)
- Authorization changes
- Data exports

Audit
Log

Retention: 7 years minimum

Audit Log Schema: Must follow specifications in db_conventions.md, Section "Phase 2 Database Requirements"

4.3 Data Classification

Level	Description	Examples
Public	No restrictions	Marketing content
Internal	Employee access only	Project documents
Confidential	Need-to-know basis	Customer data, contracts
Restricted	Named individuals only	Credentials, keys

5. Network Security

5.1 Network Segmentation

```
[Internet] --> [WAF] --> [DMZ / API Gateway] --> [Application Tier] --> [Data Tier]
|
[No direct access to Data Tier from DMZ]
```

5.2 Firewall Rules

- Default deny all
- Explicit allow rules only
- No direct database access from internet
- VPN required for administrative access

5.3 API Gateway Security

The API Gateway (Phase 2) must implement:

- Rate limiting: 1000 requests/minute per client
- DDoS protection
- Input validation (OWASP standards)
- Request/response logging

6. Vendor Security Requirements



All third-party vendors must:

- Sign Data Processing Agreement (DPA)
- Provide SOC 2 Type II report
- Complete security questionnaire
- Allow security assessment of their components

Stream
Tech
Solution
s:
Security
assess
ment
schedul
ed for
January
15,
2026.
Results
must be
reviewe
d before
Phase 2
deploy
ment.

7. Incident Response

Severity Classification

Level	Description	Response Time
P1 - Critical	Data breach, system compromise	Immediate
P2 - High	Security vulnerability exploit	4 hours
P3 - Medium	Suspicious activity detected	24 hours
P4 - Low	Policy violation	72 hours

Escalation Path

- Security Engineer on-call
- Security Lead (James Morton)
- CISO
- Executive Team



8. Security Sign-Off Requirements

Phase 2 Launch Checklist

- ☐ External penetration test passed (no Critical/High findings)
- ☐ Internal penetration test passed
- ☐ API security review completed
- ☐ All vendor security assessments completed
- ☐ GDPR data mapping approved by Legal
- ☐ Security training completed by all team members
- ☐ Incident response runbook tested

Sign-off
Authority:
James
Morton,
Security
Lead

9. Contact Information

Security Team:

- Security Lead: James Morton (james.morton@company.com)
- Security Engineer: David Kim (david.kim@company.com)
- Security Hotline: security@company.com

For
security
incidents:
security-incident@company.com (24/7 monitored)

Document Owner: James Morton, Security Lead

Next Review Date: April 1, 2026